

Stake.Link Withdrawals Audit Summary

Prepared by Cyfrin

Version 2.0

Lead Auditors

0kage

Hans

September 17, 2024

Contents

1 About Cyfrin 2

2 About This Document 2

3 Disclaimer 2

4 Copyright and License 2

5 Audit Overview 3

6 Audit Scope 4

7 Risk Classification 4

8 Protocol Summary 4

9 Attestation 5

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for STAKE.LINK on Stake.Link Withdrawals. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.0 dated September 17, 2024, was delivered to STAKE.LINK, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from STAKE.LINK or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 15 days, the Cyfrin team conducted an audit on the Stake.Link Withdrawals code provided by STAKE.LINK. The findings consist of 2 Critical, 5 High, 6 Medium & 5 Low severity issues with the remainder being gas optimizations.

Summary

Project Name	Stake.Link Withdrawals
Repository	contracts
Commit	aa0efea6a93c...
Audit Timeline	July 29th - August 16th, 2024
Methods	Manual Review, Stateful Fuzzing

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	2	2	0
High Risk	5	5	0
Medium Risk	6	6	0
Low Risk	5	0	5
Informational	0	0	0
Gas Optimizations	3	0	3
Total	21	13	8

6 Audit Scope

The audit scope was limited to Solidity contracts that govern the core on-chain operations of stake.link staking infrastructure. This audit focused on the impact of adding withdrawal support to existing vault strategies. Specifically we looked at the changes made in the PR and their impact to the existing contracts deployed on-chain.

The following contracts were included in the scope of the audit:

```
linkStaking/base/Vault.sol
linkStaking/base/VaultControllerStrategy.sol
linkStaking/CommunityVault.sol
linkStaking/CommunityVCS.sol
linkStaking/OperatorVault.sol
linkStaking/OperatorVCS.sol
linkStaking/FundFlowController.sol
linkStaking/PPKeeper.sol
metisStaking/SequencerVCS.sol
core/priorityPool/PriorityPool.sol
core/priorityPool/WithdrawalPool.sol
core/base/Strategy.sol
core/base/StakingRewardsPool.sol

src/interfaces/IVault.sol
src/interfaces/IStrategy.sol
src/interfaces/IStaking.sol
src/interfaces/IRewardVault.sol
src/interfaces/IStakingPool.sol
src/interfaces/IPriorityPool.sol
src/interfaces/IWithdrawalPool.sol
```

This scope encompasses the core contracts responsible for staking strategies specific to Chainlink, vault management, reward distribution, and overall fund flow control. It includes base contracts, specific implementations for community and operator staking, pool management, and auxiliary components such as the fund flow controller.

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

Current audit looked into the vault based staking infrastructure centered around Chainlink staking. A system of smart contracts are designed to manage staking, rewards, and fund flows for both community and operator vaults. At its core, the protocol utilizes two primary strategies: the Community Vault Control Strategy (CommunityVCS) and the Operator Vault Control Strategy (OperatorVCS).

These strategies manage multiple vaults that interact with Chainlink's staking contracts. The CommunityVCS handles community stakers, while the OperatorVCS manages operators. Both strategies are responsible for:

- Depositing funds into individual vaults, which then stake in Chainlink's contracts
- Managing the creation and allocation of new vaults
- Handling reward accrual and distribution from Chainlink staking

Rewards generated from Chainlink staking are crucial to the system's incentive structure. The process works as follows:

- Rewards accumulate in the individual vaults managed by CommunityVCS and OperatorVCS.
- Periodically, the `updateStrategyRewards` function is called on the Staking Pool.
- This function, in turn, calls `updateDeposits` on each strategy (CommunityVCS and OperatorVCS).
- The strategies calculate the change in deposits (which includes accrued rewards from Chainlink staking) and return this information to the Staking Pool.
- The Staking Pool then updates its `totalStaked` value, effectively distributing the rewards among all stakers.

This mechanism ensures that rewards from Chainlink staking are fairly distributed to all participants in the stake.link system, proportional to their stake.

While both the Community and Operator controlled strategies are already deployed on-chain, this audit focused on new contract upgrades centered around supporting withdrawals for stakers.

9 Attestation

Cyfrin attests that it performed a security review of the Stake.Link Withdrawals code provided by STAKE.LINK.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2024-09-17-cyfrin-stake-link-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to STAKE.LINK has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=fa2d9657f3ab10b1d8fdea0c7338b7ad08134a3d721d26f13c2130983b7f1c8b
F=2024-09-17-cyfrin-stake-link-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.